

NEXFRAME FILMS

"The Future of Filmmaking"

PDF MAESTRO v2 PARA CODEX / OPENAI

Sistema completo SaaS cinematografico con IA, login Google, panel administrador, panel usuario, planes de suscripcion, Stripe, PayPal, seguridad avanzada, API Collection, multiidioma y temas visuales.

PROYECTO	NEXFRAME FILMS - FULL SYSTEM v2
BASE	NEXFRAME_FILMS_CODEX_MASTER v1 + expansion SaaS comercial
STACK	Next.js 14/15, React, Tailwind, PostgreSQL, Prisma, Auth.js/NextAuth, Stripe, PayPal, Redis, S3/R2, Docker
OBJETIVO	Codex debe construir una plataforma funcional, con cero botones vacios y cero pantallas de relleno
OWNER	YANKYFILMS / Jean Carlos
ESTADO	Especificacion profesional lista para implementacion

Regla principal: ninguna API key debe ir al cliente. Toda clave de Kling, OpenAI, Stripe, PayPal y proveedores externos vive solo en variables de entorno del servidor o vault.

INDICE DE CONTENIDOS

Seccion	Contenido
01	Mandato Codex y alcance del sistema
02	Arquitectura SaaS completa
03	Modelo de datos y permisos
04	Login Google y autenticacion
05	Panel administrador
06	Panel de usuario
07	API Collection completa
08	Cerebro de rutas, estados y acciones
09	Pagos Stripe y PayPal
10	Sistema de suscripciones y creditos
11	Seguridad avanzada y hardening
12	Multiidioma e internacionalizacion
13	Temas visuales y personalizacion
14	Botones funcionales por pantalla
15	Studios IA y flujos productivos
16	Gestion de proyectos y archivos
17	Notificaciones, emails y soporte
18	Analitica, logs y auditoria
19	Deployment, dominios y backups
20	Variables de entorno
21	Checklist final de entrega
22	Anexos tecnicos y referencias

01 - MANDATO CODEX Y ALCANCE DEL SISTEMA

Codex debe convertir NEXFRAME FILMS en una plataforma SaaS completa para produccion cinematografica con IA. El resultado no es una demo: es una aplicacion profesional con autenticacion real, permisos, paneles separados, pagos, API server-side, historial persistente, seguridad y despliegue reproducible.

El PDF v1 define la base: fork de Open Generative AI, rediseño visual NEXFRAME, reemplazo de Muapi por Kling AI API, studios expandidos, dashboard, rutas API y checklist final. Esta version v2 conserva esa base y anade la capa comercial, segura y multiusuario.

Reglas de construccion obligatorias

Regla	Implementacion obligatoria
Cero placeholders	Cada boton dispara una accion real: navegar, abrir modal, guardar, generar, descargar, copiar, pagar, cancelar o mostrar error controlado.
No keys en frontend	Eliminar NEXT_PUBLIC_KLING_API_KEY. Usar KLING_API_KEY solo servidor. El navegador llama a /api/nf/*, nunca a Kling directo.
Separacion de roles	ADMIN controla sistema, usuarios, planes, limites, modelos y logs. USER solo ve sus proyectos, billing y generaciones.
Trazabilidad	Toda accion sensible se registra en audit_logs con user_id, ip_hash, user_agent, accion y resultado.
Producto comercial	Login Google, planes, Stripe Checkout, PayPal Subscriptions, portal de facturacion, webhooks verificados.
No promesas falsas	Implementar seguridad alta por capas. No existe seguridad 100% invulnerable; el objetivo es defensa empresarial y respuesta automatizada.

02 - ARQUITECTURA SAAS COMPLETA

La aplicacion queda dividida en frontend, backend Next.js API routes/server actions, base de datos, cola de trabajos, almacenamiento de archivos, pasarelas de pago y servicios de observabilidad.

Diagrama logico

Usuario -> Web App Next.js -> Auth.js Session -> Middleware RBAC
|-> /api/nf/generate/* -> Job Queue -> Kling/OpenAI server-side
|-> /api/billing/* -> Stripe / PayPal
|-> /api/admin/* -> Admin services + audit logs
|-> PostgreSQL + Prisma -> usuarios, roles, proyectos, creditos
|-> Redis -> rate limit, job progress, bloqueo IP
|-> S3/R2 -> imagenes, videos, audio, thumbnails
|-> Email provider -> facturas, alertas, soporte

Stack recomendado

Capa	Herramienta	Uso
App	Next.js App Router	Frontend, API routes, middleware, server actions
UI	Tailwind + Radix + Lucide-react	Interfaz profesional, accesible y responsive
Auth	Auth.js/NextAuth + Google Provider	OAuth Google, sesiones, JWT/DB sessions
DB	PostgreSQL + Prisma	Modelo relacional para SaaS
Cache/colas	Redis + BullMQ o Upstash QStash	Jobs async, rate limit, progreso
Storage	Cloudflare R2 / S3 compatible	Archivos generados y uploads privados
Pagos	Stripe + PayPal	Suscripciones, checkout, webhooks, portal
Seguridad	Middleware RBAC + rate limit + WAF	Proteccion de rutas y APIs
Observabilidad	Sentry + OpenTelemetry + logs DB	Errores, eventos y auditoria
Deploy	Vercel o Docker/Coolify en GRANOSCAR	Publicacion cloud o self-hosted

03 - MODELO DE DATOS Y PERMISOS

La base de datos debe permitir que el administrador controle usuarios, planes, generaciones, pagos, limites, API providers y seguridad. Este modelo esta pensado para Prisma + PostgreSQL.

Tablas principales

Tabla	Campos clave	Objetivo
users	id, email, name, image, role, status, locale, theme, createdAt	Identidad y perfil del usuario. role: ADMIN, USER, SUPPORT.
accounts	provider, providerAccountId, access_token, refresh_token, userId	Cuentas OAuth gestionadas por Auth.js.
sessions	sessionToken, userId, expires	Sesiones persistentes en DB.
plans	id, slug, name, priceMonthly, currency, credits, features, isActive	Planes visibles en pricing y controlables por admin.
subscriptions	userId, provider, providerSubId, status, planId, currentPeriodEnd	Estado de pago en Stripe/PayPal.
credit_ledger	userId, amount, reason, provider, jobId, createdAt	Libro de creditos: recargas, consumos y ajustes admin.
projects	id, userId, title, type, status, visibility, thumbnailUrl	Contenedor de trabajos: documental, videoclip, imagen, audio.
generations	projectId, userId, provider, model, type, promptHash, status, costCredits, outputUrl	Cada tarea enviada a IA.
assets	userId, projectId, kind, storageKey, mime, size, checksum, isPublic	Uploads y resultados en almacenamiento privado.
api_providers	name, baseUrl, status, rateLimit, enabled, secretRef	Control admin de Kling, OpenAI y futuros proveedores.
audit_logs	actorId, action, entity, entityId, ipHash, userAgentHash, metadata	Auditoria para seguridad y soporte.
blocked_ips	ipHash, reason, expiresAt, createdBy	Bloqueo por ataques o abuso.

Permisos por rol

Modulo	ADMIN	USER	ANON
Dashboard admin	Total: usuarios, pagos, seguridad, providers, logs	No	No
Dashboard usuario	Puede entrar a cualquier usuario en modo soporte con auditoria	Solo propios datos	No
Generar IA	Sin limites o limites admin	Segun plan/creditos	No
API keys	Ver estado, rotar, desactivar, nunca ver secret completo	No ve secrets	No
Pagos	Ver facturas, reembolsos manuales segun integracion	Gestionar su suscripcion	Ver pricing
Archivos	Gestion y borrado legal	Solo propios assets	No
Logs seguridad	Lectura y accion	No	No

04 - LOGIN GOOGLE Y AUTENTICACION

El login de Google debe implementarse con OAuth/OpenID Connect mediante Auth.js/NextAuth. Google entrega identidad verificada, pero NEXFRAME decide permisos, plan y acceso usando su propia base de datos.

Pantallas de auth

Ruta	Contenido	Botones funcionales
/login	Logo, frase de marca, boton Google, enlace terminos, selector idioma	Continuar con Google -> signIn("google"); Cambiar idioma; Ver privacidad
/auth/error	Mensaje claro, codigo de error, volver a login	Reintentar; Soporte
/logout	Confirmacion de cierre	Cerrar sesion; Cancelar
/onboarding	Nombre, uso principal, idioma, tema inicial	Guardar perfil; Saltar; Ir al dashboard

Flujo tecnico

1. Usuario pulsa Continuar con Google.
2. Auth.js redirige a Google OAuth/OpenID Connect.
3. Google devuelve code al callback autorizado.
4. Auth.js valida token, crea/actualiza user/account/session.
5. Middleware lee session y role desde DB.
6. Si role=ADMIN -> /admin. Si role=USER -> /dashboard.
7. Si usuario nuevo -> /onboarding antes de usar credits.

Middleware de proteccion

```
// middleware.ts - esquema obligatorio
const PUBLIC_ROUTES = ['/', '/login', '/pricing', '/legal', '/api/webhooks/stripe', '/api/webhooks/paypal'];
const ADMIN_PREFIX = '/admin';

export default auth((req) => {
  const { pathname } = req.nextUrl;
  if (PUBLIC_ROUTES.some(r => pathname.startsWith(r))) return NextResponse.next();
  if (!req.auth?.user) return NextResponse.redirect(new URL('/login', req.url));
  if (pathname.startsWith(ADMIN_PREFIX) && req.auth.user.role !== 'ADMIN') {
    return NextResponse.redirect(new URL('/dashboard', req.url));
  }
  return NextResponse.next();
});
```

05 - PANEL ADMINISTRADOR

El administrador tiene un panel privado separado de los usuarios. Debe permitir controlar toda la plataforma sin editar codigo: usuarios, planes, limites, proveedores API, seguridad, temas, textos, idiomas, jobs y pagos.

Rutas admin

Ruta	Objetivo	Acciones/botones obligatorios
/admin	Resumen ejecutivo	Ver ingresos, usuarios activos, jobs, errores, alertas; botones: refrescar, exportar CSV, ir a seguridad
/admin/users	Gestion de usuarios	Buscar, filtrar, abrir perfil, suspender, activar, cambiar rol, ajustar credits, impersonate seguro con audit log
/admin/plans	Planes y precios	Crear plan, editar precio visible, activar/desactivar, ordenar, duplicar, sincronizar Stripe/PayPal
/admin/billing	Pagos y suscripciones	Ver estado, buscar invoice, cancelar suscripcion, abrir Stripe/PayPal dashboard, reintentar sync
/admin/providers	Kling/OpenAI/providers	Activar/desactivar proveedor, probar conexion, rotar secreto, ver latencia, set default model
/admin/security	Seguridad	Ver IPs bloqueadas, intentos fallidos, reglas rate limit, desbloquear, bloquear manual, exportar audit log
/admin/content	Textos/idiomas	Editar labels, revisar traducciones, publicar cambios
/admin/themes	Temas visuales	Crear tema, previsualizar, publicar, marcar por defecto
/admin/jobs	Cola de generaciones	Ver job, reintentar, cancelar, reembolsar credits, descargar output
/admin/settings	Sistema	Dominio, email soporte, legal links, modo mantenimiento, backups

Dashboard admin - widgets

Widget	Metrica	Accion al hacer click
Ingresos mensuales	MRR Stripe + PayPal	Abrir /admin/billing?range=month
Usuarios activos	Usuarios con sesion/generacion 30 dias	Abrir /admin/users?active=true
Jobs IA	En cola, procesando, fallidos, exitosos	Abrir /admin/jobs
Consumo API	Coste por proveedor/modelo	Abrir /admin/providers/usage
Seguridad	Bloqueos, 429, 401, intentos admin	Abrir /admin/security
Errores	Errores recientes Sentry/logs	Abrir detalle tecnico

06 - PANEL DE USUARIO

El panel de usuario es la zona privada para clientes suscritos. Debe sentirse como una productora digital: proyectos, credits, studios, descargas, facturacion y soporte.

Rutas usuario

Ruta	Contenido	Botones funcionales
/dashboard	Resumen personal: credits, proyectos recientes, continuar creando	Nuevo proyecto, abrir studio, comprar credits, ver plan
/projects	Lista de proyectos con filtros	Crear, abrir, duplicar, archivar, borrar, exportar
/projects/[id]	Timeline de assets y generaciones	Generar escena, subir archivo, renombrar, descargar paquete, compartir link privado
/studio/video	Text/Image-to-video	Generar, subir imagen, limpiar, guardar preset, descargar, enviar a proyecto
/studio/image	Text-to-image y referencia	Generar, variaciones, upscaling si proveedor lo permite, descargar
/studio/sound	Audio/FX	Generar, preescuchar, descargar, enviar a video
/studio/lipsync	Avatar/lip sync	Subir imagen/video/audio, validar, generar, descargar
/studio/documentary	Tema -> guion -> escenas -> video	Generar guion, editar, dividir escenas, generar batch, guardar proyecto
/studio/musicvideo	Audio -> storyboard -> escenas	Subir cancion, analizar estructura, generar prompts, generar escenas
/billing	Plan, facturas, metodo de pago	Upgrade, downgrade, abrir portal Stripe, gestionar PayPal, cancelar
/settings	Perfil, idioma, tema, privacidad	Guardar cambios, exportar datos, borrar cuenta

Estados del usuario

Estado	Puede hacer	Bloqueos visibles
Nuevo sin plan	Ver pricing, onboarding, demos publicas	Generar IA bloqueado con CTA a plan
Trial	Generar con credits trial	Limites de agua/outputs segun plan
Activo	Usar todos los modulos permitidos	Ninguno salvo credits agotados
Past_due	Ver proyectos, descargar propios	Generar bloqueado hasta resolver pago
Cancelado	Ver historial por periodo definido	Upgrade/reactivar
Suspendido	No puede acceder salvo soporte/legal	Pantalla de contacto soporte

07 - API COLLECTION COMPLETA

La API Collection es el contrato interno de NEXFRAME. Sirve para Postman/Insomnia/Thunder Client y tambien para que Codex implemente las rutas sin improvisar. Todas las rutas devuelven JSON uniforme: ok, data, error, requestId.

Formato de respuesta

```
// Exito
{ "ok": true, "data": { ... }, "requestId": "req_..." }

// Error
{ "ok": false, "error": { "code": "LIMIT_REACHED", "message": "Creditos insuficientes" }, "requestId": "req_..." }
```

Rutas publicas

Metodo	Ruta	Auth	Hace
GET	/api/public/config	No	Devuelve idiomas, temas publicos, planes activos sin secretos.
GET	/api/public/plans	No	Listado de planes visibles para pricing.
POST	/api/contact	No + rate limit	Envia mensaje a soporte y crea ticket.
POST	/api/waitlist	No + captcha	Registra email en lista de espera.

Rutas auth/user

Metodo	Ruta	Rol	Hace
GET	/api/me	USER	Perfil, plan, creditos, permisos, flags.
PATCH	/api/me	USER	Actualiza nombre, idioma, tema, preferencias.
GET	/api/me/usage	USER	Consumo por dia, proyecto, studio y modelo.
POST	/api/me/export	USER	Solicita exportacion de datos.
DELETE	/api/me	USER	Solicita borrado de cuenta con confirmacion.

Rutas de proyectos y assets

Metodo	Ruta	Rol	Hace
GET	/api/projects	USER	Lista proyectos propios con paginacion.
POST	/api/projects	USER	Crea proyecto. Body: title,type,locale.
GET	/api/projects/[id]	OWNER/ADMIN	Detalle completo del proyecto.
PATCH	/api/projects/[id]	OWNER/ADMIN	Renombra, cambia status, visibility.
DELETE	/api/projects/[id]	OWNER/ADMIN	Soft delete y auditoria.
POST	/api/assets/upload-url	USER	Genera signed URL de subida privada.
GET	/api/assets/[id]/download	OWNER/ADMIN	Genera signed URL temporal de descarga.

Rutas IA

Metodo	Ruta	Rol	Boton que la llama	Hace
POST	/api/nf/video/text	USER	Generar video	Valida creditos, crea job, llama Kling T2V server-side.
POST	/api/nf/video/image	USER	Generar desde imagen	Sube/usa asset y llama Kling I2V.
POST	/api/nf/image/text	USER	Generar imagen	Kling/Kolors T2I.
POST	/api/nf/sound/text	USER	Generar audio	Genera audio/FX.
POST	/api/nf/lipsync	USER	Generar lip sync	Valida video/imagen/audio y procesa.
POST	/api/nf/script/generate	USER	Generar guion	Usa LLM server-side, devuelve guion estructurado.
POST	/api/nf/script/scenes	USER	Dividir escenas	Convierte guion en escenas, prompts y shots.
GET	/api/nf/jobs/[id]	OWNER/ADMIN	Barra progreso	Estado: queued, running, succeeded, failed.

Metodo	Ruta	Rol	Boton que la llama	Hace
POST	/api/nf/jobs/[id]/cancel	OWNER/ADMIN	Cancelar	Cancela si el proveedor lo permite y reembolsa segun reglas.

Rutas billing

Metodo	Ruta	Auth	Hace
POST	/api/billing/stripe/checkout	USER	Crea Stripe Checkout Session para plan/credit pack.
POST	/api/billing/stripe/portal	USER	Crea link al Customer Portal.
POST	/api/webhooks/stripe	Firma Stripe	Procesa invoices, checkout, subscriptions, refunds.
POST	/api/billing/paypal/create-subscription	USER	Crea suscripcion PayPal para un plan.
POST	/api/billing/paypal/capture-order	USER	Captura compra unica si se usa credit pack.
POST	/api/webhooks/paypal	Firma PayPal	Actualiza subscription/payment status.
GET	/api/billing/invoices	USER	Lista facturas y recibos del usuario.

Rutas admin

Metodo	Ruta	Hace
GET	/api/admin/metrics	KPIs del dashboard admin.
GET	/api/admin/users	Busqueda usuarios, filtros y paginacion.
PATCH	/api/admin/users/[id]	Cambiar rol/status/creditos con auditoria.
GET	/api/admin/audit	Consultar audit_logs.
POST	/api/admin/security/block-ip	Bloquear IP hash temporal/permanente.
DELETE	/api/admin/security/block-ip/[id]	Desbloquear.
POST	/api/admin/providers/[id]/test	Probar conexion proveedor sin exponer secret.
POST	/api/admin/providers/[id]/rotate	Rotar secreto via vault/env reference.
POST	/api/admin/plans/sync	Sincronizar planes con Stripe/PayPal.

08 - CEREBRO DE RUTAS, ESTADOS Y ACCIONES

El cerebro del sistema decide a donde va cada usuario, que ve, que boton aparece habilitado y que ocurre despues de cada accion. Debe estar centralizado para evitar pantallas rotas.

Router mental

Condicion	Destino	Motivo
No autenticado entra a /dashboard	/login	Proteger contenido privado.
Autenticado sin onboarding	/onboarding	Completar idioma, uso y defaults.
ADMIN entra a /dashboard	/admin	Administracion primero.
USER activo entra a /	/dashboard	Experiencia de cliente.
USER sin plan intenta generar	/pricing?reason=no_plan	Conversion clara.
USER sin credits intenta generar	/billing?reason=credits	Compra o upgrade.
Pago exitoso Stripe/PayPal	/dashboard?billing=success	Activar plan/credits via webhook.
Job creado	/jobs/[id] o panel lateral	Progreso y polling.
Job terminado	Proyecto + asset resultante	Guardar y mostrar descarga.

Maquina de estado de generacion

IDLE -> VALIDATING -> BILLING_CHECK -> CREDITS_RESERVED -> QUEUED -> RUNNING
RUNNING -> SUCCEEDED -> ASSET_SAVED -> CREDITS_CAPTURED -> DONE
RUNNING -> FAILED -> CREDITS_REFUNDED -> ERROR_VISIBLE
QUEUED/RUNNING -> CANCEL_REQUESTED -> CANCELLED -> CREDITS_REFUNDED

Boton universal de generacion

Estado	Texto del boton	Click
Sin prompt/archivo requerido	Completa los campos	No envia. Marca campos requeridos.
Sin login	Inicia sesion para generar	Abre /login.
Sin plan	Activa un plan	Abre /pricing.
Sin credits	Comprar credits	Abre /billing.
Listo	Generar	POST a ruta IA correspondiente.
Validando	Validando...	Disabled.
En cola/proceso	Generando...	Disabled + mostrar cancelar si permitido.
Exito	Generar otra version	Resetea estado manteniendo prompt.
Error	Reintentar	Reenvia con mismo payload si el error es recuperable.

09 - PAGOS STRIPE Y PAYPAL

El sistema debe soportar Stripe y PayPal sin mezclar responsabilidades. La base de datos guarda un estado normalizado de suscripcion, mientras cada provider mantiene sus propios IDs.

Stripe

Elemento	Implementacion
Checkout	/api/billing/stripe/checkout crea session con mode=subscription o payment.
Customer	Crear o reutilizar stripeCustomerId por usuario.
Portal	/api/billing/stripe/portal abre Customer Portal para cambiar tarjeta/cancelar si se permite.
Webhooks	Verificar firma stripe-signature. Eventos minimos: checkout.session.completed, customer.subscription.created/updated/deleted, invoice.paid, invoice.payment_failed.
Seguridad	Nunca confiar en query params de success. Activar plan solo por webhook verificado.

PayPal

Elemento	Implementacion
Plans	Crear planes PayPal equivalentes a los planes internos o mapear paypalPlanId.
Subscription	/api/billing/paypal/create-subscription crea la suscripcion y devuelve approval_url.
Webhooks	Verificar firma PayPal y procesar BILLING.SUBSCRIPTION.ACTIVATED, CANCELLED, SUSPENDED y PAYMENT.SALE.COMPLETED si aplica.
OAuth server-side	Obtener access token PayPal solo en servidor con client id/secret.
Sincronizacion	Job nocturno verifica suscripciones dudosas con PayPal API.

Pantalla pricing

Boton	Accion
Mensual/Anual	Alterna precios y recalcula ahorro.
Elegir plan con Stripe	Crea checkout Stripe.
Elegir plan con PayPal	Crea subscription PayPal y redirige approval.

Boton	Accion
Comparar planes	Abre tabla completa de features.
Hablar con ventas	Abre formulario contacto con asunto enterprise.

10 - SISTEMA DE SUSCRIPCIONES Y CREDITOS

Los creditos protegen los costes de IA. Cada generacion reserva creditos antes de llamar al proveedor, captura al terminar con exito y reembolsa si falla por error tecnico.

Planes sugeridos

Plan	Precio referencial	Creditos/mes	Incluye
Free/Trial	\$0	50 una vez	Prueba con watermark o limites bajos.
Creator	\$19/mes	800	Video, image, sound, historial 30 dias.
Studio	\$49/mes	2500	Batch, documentary, music video, storage mayor.
Pro	\$99/mes	7000	Prioridad, modelos premium, export avanzado.
Enterprise	Custom	Custom	Usuarios equipo, SSO futuro, SLA, soporte.

Reglas de creditos

Evento	Movimiento
Suscripcion activada	Agregar creditos del periodo o reset segun plan.
Generacion inicia	Reservar costo estimado en ledger.
Generacion exitosa	Capturar reserva; guardar costo real si se conoce.
Generacion fallida por proveedor	Reembolsar reserva.
Cancelacion usuario	Mantener creditos hasta currentPeriodEnd si politica lo permite.
Admin ajuste manual	Registrar reason obligatorio y actorId.

11 - SEGURIDAD AVANZADA Y HARDENING

Se implementa seguridad por capas: autenticacion, autorizacion, validacion, aislamiento de secretos, rate limits, WAF, bloqueo por abuso, auditoria y backups. Ningun sistema puede prometer invulnerabilidad absoluta; lo correcto es defensa profunda, minima exposicion y respuesta rapida.

Controles obligatorios

Capa	Control	Detalle
Secrets	Server-only env + vault	KLING_API_KEY, OPENAI_API_KEY, STRIPE_SECRET, PAYPAL_SECRET nunca llegan al navegador.
Auth	OAuth + session DB	Cookies httpOnly, secure, sameSite=lax/strict segun ruta.
RBAC	Middleware + DB check	No confiar solo en UI. Cada /api/admin valida role.
CSRF	Proteccion en mutaciones	Server actions/API con token o sameSite + origin checks.
Validacion	Zod schemas	Validar body, query params, file mime, size y aspect ratio.
Rate limit	Redis sliding window	Por IP, userId, ruta y accion de generacion.
WAF	Cloudflare/Vercel Firewall	Bloquear patrones SQLi/XSS, paises si procede, bots agresivos.
Uploads	Signed URLs + antivirus opcional	No ejecutar archivos; comprobar MIME real y extension.
DB	Principio minimo	Usuario DB con permisos limitados; migraciones separadas.
Headers	CSP/HSTS/X-Frame	Evitar clickjacking, mixed content y inyecciones.

Capa	Control	Detalle
Logs	Audit log inmutable	Acciones admin, pagos, login, errores, cambios de permisos.
Backups	Cifrado + restauracion probada	Backups diarios, retention, prueba mensual.

Bloqueo de IP y respuesta a ataques

La aplicacion no puede “cambiar la IP del atacante”; lo que si debe hacer es detectar abuso, bloquear la IP/origen, endurecer reglas y registrar evidencia. Para infraestructura propia, se puede anadir fail2ban/nginx y Cloudflare para bloqueo perimetral.

Reglas minimas:

- 5 intentos fallidos de admin en 10 min -> bloqueo 1 hora.
- 100 requests a /api/nf/* en 10 min sin exito -> bloqueo 6 horas.
- Payload con patrones de inyeccion repetidos -> bloqueo 24 horas.
- Usuario autenticado abusivo -> congelar generacion, no borrar cuenta automaticamente.
- Todo bloqueo guarda ipHash, reason, route, userAgentHash, expiresAt.

Cabeceras recomendadas

Content-Security-Policy: default-src 'self'; img-src 'self' data: blob: https:; media-src 'self' blob: https:; connect-src 'self' https://api.stripe.com;
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()

12 - MULTIIDIOMA E INTERNACIONALIZACION

El sistema debe cargar textos desde diccionarios y no desde strings dispersos en componentes. Idiomas iniciales: espanol, ingles, italiano, portugues, frances y aleman.

Idiomas

Codigo	Nombre UI	Ruta
es	Espanol	/es/dashboard
en	English	/en/dashboard
it	Italiano	/it/dashboard
pt	Portugues	/pt/dashboard
fr	Francais	/fr/dashboard
de	Deutsch	/de/dashboard

Estructura de diccionarios

```

/messages
  es.json
  en.json
  it.json
  pt.json
  fr.json
  de.json

{
  "nav.dashboard": "Dashboard",
  "nav.projects": "Proyectos",
  "studio.video.title": "Video Studio",
  "button.generate": "Generar",
  "button.download": "Descargar",
  "billing.upgrade": "Mejorar plan",
  "security.noAccess": "No tienes permiso para ver esta seccion"
}
```

Botones multiidioma base

Key	ES	EN	IT	PT	FR	DE
button.generate	Generar	Generate	Genera	Gerar	Generer	Generieren
button.download	Descargar	Download	Scarica	Baixar	Telecharger	Herunterladen

Key	ES	EN	IT	PT	FR	DE
button.cancel	Cancelar	Cancel	Annulla	Cancelar	Annuler	Abbrechen
button.save	Guardar	Save	Salva	Salvar	Enregistrer	Speichern
button.upgrade	Mejorar plan	Upgrade	Aggiorna	Melhorar	Ameliorer	Upgrade
button.loginGoogle	Continuar con Google	Continue with Google	Continua con Google	Continuar com Google	Continuer avec Google	Mit Google fortfahren

13 - TEMAS VISUALES Y PERSONALIZACION

El administrador puede activar varios temas. El usuario puede elegir tema si su plan lo permite. Los temas cambian variables CSS, no reescriben componentes.

Temas iniciales

Tema	Uso	Colores clave
NexFrame Classic	Default cinematografico rojo/negro/dorado	black #0A0A0A, red #E02020, gold #D4AF37
Midnight Blue	Cientes corporativos	navy #07111F, blue #2563EB, cyan #06B6D4
Gold Premiere	Premium/Pro	black #050505, gold #D4AF37, amber #F59E0B
Clean Light	Documentacion/admin diurno	white #FFFFFF, slate #0F172A, red #E02020
Neon Studio	Creativo/social	black #09090B, purple #8B5CF6, cyan #06B6D4

Variables CSS

```
:root[data-theme="nexframe"] {
  --bg: #0A0A0A;
  --surface: #161616;
  --border: #222222;
  --primary: #E02020;
  --secondary: #D4AF37;
  --text: #FFFFFF;
  --muted: #9CA3AF;
}
```

14 - BOTONES FUNCIONALES POR PANTALLA

Cada boton debe tener una accion real. Si una funcion no esta disponible por plan, el boton no desaparece: se muestra bloqueado con tooltip y CTA de upgrade.

Pantalla	Boton	Accion real	Feedback
TopBar	Menu	toggleSidebar()	Sidebar abre/cierra
TopBar	Campana	/notifications	Badge limpio al abrir
TopBar	API status admin	/admin/providers	Solo admin
Login	Continuar con Google	signIn("google")	Spinner y error claro
Dashboard	Nuevo proyecto	POST /api/projects	Redirige a proyecto
Dashboard	Comprar creditos	/billing	Abre billing
Projects	Duplicar	POST /api/projects/[id]/duplicate	Copia creada
Projects	Archivar	PATCH status=archived	Sale de activos
Studio	Generar	POST ruta IA	Job creado + progreso
Studio	Cancelar	POST /api/nf/jobs/[id]/cancel	Estado cancelado
Studio	Descargar	GET signed download	Descarga segura
Studio	Guardar preset	POST /api/presets	Preset visible
Billing	Upgrade Stripe	POST /api/billing/stripe/checkout	Redirect checkout

Pantalla	Boton	Accion real	Feedback
Billing	PayPal	POST /api/billing/paypal/create-subscription	Redirect approval
Billing	Cancelar plan	Provider portal / cancel flow	Confirmacion
Admin Users	Suspender	PATCH user.status=suspended	Audit log
Admin Security	Bloquear IP	POST block-ip	Regla activa
Admin Providers	Test conexion	POST provider/test	Latencia/status
Admin Plans	Publicar plan	PATCH isActive=true	Pricing actualizado
Admin Jobs	Reintentar job	POST retry	Nueva ejecucion
Settings	Cambiar idioma	PATCH /api/me locale	Reload locale
Settings	Cambiar tema	PATCH /api/me theme	Aplicacion inmediata

15 - STUDIOS IA Y FLUJOS PRODUCTIVOS

Los studios definidos en v1 se mantienen y se conectan al backend seguro. El cliente nunca llama directamente a Kling; cada studio crea jobs internos y el backend ejecuta la integracion.

Studio	Inputs	Output	Ruta API	Costo creditos
Video Studio T2V	prompt, negative, model, ratio, duration, mode	video mp4/webm	/api/nf/video/text	Por modelo + duracion
Video Studio I2V	image asset, prompt, model, ratio, duration	video	/api/nf/video/image	Mas alto por upload /modelo
Image Studio	prompt, ref image, ratio, n	imagenes	/api/nf/image/text	Por imagen
Sound Studio	prompt, duration, style	audio wav/mp3	/api/nf/sound/text	Por segundos
Effects Studio	image/video, effect_scene	video con efecto	/api/nf/effects	Por duracion
Lip Sync Studio	avatar image/video, audio	video lip sync	/api/nf/lipsync	Por segundos
Documentary Studio	tema, estilo, duracion	guion, escenas, videos	/api/nf/script/* + video	Por escenas
Music Video Studio	audio, estilo, ritmo	storyboard + clips	/api/nf/musicvideo/*	Por clips

Documentary Studio - flujo

1. Usuario escribe tema, tono, duracion, idioma.
2. Sistema genera guion con estructura: hook, actos, narracion, lista de escenas.
3. Usuario edita guion; boton Guardar version.
4. Sistema divide escenas con prompts visuales, audio/narracion y camara.
5. Usuario genera escenas por lote o una por una.
6. Resultados se guardan en proyecto con timeline y descargas.

Music Video Studio - flujo

1. Usuario sube audio.
2. Sistema guarda asset y extrae metadata basica: duracion, nombre, BPM si se integra analizador.
3. Usuario elige estilo visual, artista/referencia propia, formato 9:16/16:9.
4. Script Engine genera storyboard por secciones: intro, verso, coro, puente, outro.
5. Se generan clips y se guardan en timeline.

16 - GESTION DE PROYECTOS Y ARCHIVOS

Los assets son privados por defecto. Ningun archivo generado debe exponerse con URL permanente publica salvo que el usuario cree un share link temporal.

Estructura de storage

```
/r2-or-s3-bucket
users/{userId}/uploads/{assetId}.{ext}
users/{userId}/projects/{projectId}/outputs/{generationId}.{ext}
users/{userId}/projects/{projectId}/thumbs/{assetId}.jpg
exports/{projectId}/{exportId}.zip
```

Acciones de proyecto

Accion	Implementacion
Crear proyecto	POST /api/projects con title/type/locale.
Auto-guardar generaciones	Cada resultado se une a projectId si existe o crea proyecto temporal.
Descargar paquete	Genera ZIP con outputs, prompts, metadata y licencia/terminos.
Compartir	Crea signed share link con expiracion y permisos read-only.
Borrar	Soft delete DB + job de borrado fisico diferido.
Exportar metadata	JSON/CSV de prompts, modelos, fechas y creditos.

17 - NOTIFICACIONES, EMAILS Y SOPORTE

Eventos que notifican

Evento	Canal	Mensaje
Pago exitoso	Email + in-app	Plan activado y creditos disponibles.
Pago fallido	Email + in-app	Actualizar metodo de pago.
Job terminado	In-app opcional email	Tu video/imagen/audio esta listo.
Job fallido	In-app	Se reembolsaron creditos si aplica.
Login sospechoso/admin	Email admin	Actividad sensible detectada.
Soporte recibido	Email	Ticket creado con numero.

Centro de soporte

Ruta	Funciones
/support	Formulario: asunto, categoria, mensaje, proyecto relacionado, adjunto opcional.
/admin/support	Admin ve tickets, cambia estado, responde por email, vincula audit logs.
/help	FAQ editable desde admin/content.

18 - ANALITICA, LOGS Y AUDITORIA

El panel debe separar analitica de negocio, logs tecnicos y auditoria de seguridad. Los logs nunca deben guardar secrets ni prompts sensibles sin hashing/opcion de privacidad.

KPIs

Categoria	Metricas
Negocio	MRR, conversion pricing, churn, ARPU, trials activos.
Producto	Generaciones por studio, prompts por modelo, exportaciones, tiempo medio.
Costes	Coste API por proveedor/modelo, creditos consumidos, margen por plan.
Seguridad	401/403/429, intentos admin, IPs bloqueadas, usuarios suspendidos.
Calidad	Jobs fallidos, latencia, timeouts, reintentos, tickets soporte.

Audit log - acciones obligatorias

LOGIN_SUCCESS, LOGIN_FAILED, LOGOUT,
ADMIN_USER_ROLE_CHANGED, ADMIN_USER_SUSPENDED, ADMIN_CREDITS_ADJUSTED,
PLAN_CREATED, PLAN_UPDATED, PROVIDER_SECRET_ROTATED, PROVIDER_DISABLED,
JOB_CREATED, JOB_CANCELLED, JOB_RETRIED, ASSET_DELETED,
STRIPE_WEBHOOK_RECEIVED, PAYPAL_WEBHOOK_RECEIVED,
IP_BLOCKED, IP_UNBLOCKED, RATE_LIMIT_TRIGGERED

19 - DEPLOYMENT, DOMINIOS Y BACKUPS

Ambientes

Ambiente	Uso	Dominio
local	Desarrollo	localhost:3000
staging	Pruebas reales con sandbox	staging.nexframefilms.com
production	Cientes reales	nexframefilms.com

Docker compose base

```
services:
  app:
    build: .
    ports: ["3000:3000"]
    env_file: .env.production
    depends_on: [postgres, redis]
  postgres:
    image: postgres:16
    environment:
      POSTGRES_DB: nexframe
      POSTGRES_USER: nexframe
      POSTGRES_PASSWORD: ${POSTGRES_PASSWORD}
    volumes: ["pgdata:/var/lib/postgresql/data"]
  redis:
    image: redis:7-alpine
    command: redis-server --appendonly yes
    volumes: ["redisdata:/data"]
volumes:
  pgdata:
  redisdata:
```

Backups

Backup	Frecuencia	Retencion	Prueba
PostgreSQL dump cifrado	Diario	30 dias	Restauracion mensual en staging
Storage R2/S3	Versioning + lifecycle	Segun coste	Descarga aleatoria semanal
Variables/secret refs	Manual al rotar	Historico seguro	Checklist de acceso
Audit logs	Continuo	1-2 anos segun legal	Consulta y exportacion

20 - VARIABLES DE ENTORNO

Las variables con NEXT_PUBLIC_ solo pueden contener datos publicos. Secrets siempre server-side.

```
# APP
NEXT_PUBLIC_APP_NAME="NEXFRAME FILMS"
NEXT_PUBLIC_APP_URL="https://nexframefilms.com"
NODE_ENV="production"

# DATABASE
DATABASE_URL="postgresql://nexframe:password@host:5432/nexframe"
REDIS_URL="redis://default:password@host:6379"

# AUTH
AUTH_SECRET="generate-with-openssl-rand-base64-32"
AUTH_URL="https://nexframefilms.com"
GOOGLE_CLIENT_ID="..."
GOOGLE_CLIENT_SECRET="..."

# AI PROVIDERS - SERVER ONLY
KLING_API_BASE="https://api.klingai.com"
```

```

KLING_API_KEY="..."
OPENAI_API_KEY="..."

# STORAGE
S3_ENDPOINT="https://...r2.cloudflarestorage.com"
S3_ACCESS_KEY_ID="..."
S3_SECRET_ACCESS_KEY="..."
S3_BUCKET="nexframe-assets"
S3_PUBLIC_BASE_URL="" # mantener vacio si todo es privado

# STRIPE
STRIPE_SECRET_KEY="sk_live..."
STRIPE_WEBHOOK_SECRET="whsec..."
NEXT_PUBLIC_STRIPE_PUBLISHABLE_KEY="pk_live..."

# PAYPAL
PAYPAL_ENV="live"

PAYPAL_CLIENT_ID="..."
PAYPAL_CLIENT_SECRET="..."
PAYPAL_WEBHOOK_ID="..."

# EMAIL / OBSERVABILITY
RESEND_API_KEY="..."
SUPPORT_EMAIL="support@nexframefilms.com"
SENTRY_DSN="..."

```

21 - CHECKLIST FINAL DE ENTREGA

Area	Checklist
Auth	Login Google funciona; logout funciona; rutas privadas redirigen; admin protegido; cookies seguras.
Roles	ADMIN ve /admin; USER no puede acceder a /admin ni por URL ni por API; audit log registra denegaciones.
Billing	Stripe checkout; Stripe webhook verificado; PayPal subscription; PayPal webhook verificado; plan se activa solo por webhook.
Credits	Reserva, captura y reembolso funcionan; usuario sin creditos queda bloqueado con CTA.
API Collection	Todas las rutas devuelven formato ok/data/error/requestId; errores consistentes.
Studios	Video, Image, Sound, Effects, Lip Sync, Documentary, Music Video generan jobs reales.
Botones	No hay botones sin onClick, href real o disabled con motivo; no hay lorem ipsum.
Admin	Usuarios, planes, seguridad, providers, jobs y billing son controlables.
User panel	Proyectos, billing, settings, downloads y soporte funcionan.
Seguridad	Keys server-only; rate limit; RBAC server-side; headers; WAF; bloqueo IP; audit logs.
i18n	ES/EN/IT/PT/FR/DE cargan; selector funciona; textos no estan hardcodeados.
Temas	Temas cambian variables CSS; admin puede publicar; usuario puede elegir.
Deploy	Build pasa; migraciones pasan; variables cargadas; dominio HTTPS; backups configurados.

Entrega aprobada solo cuando npm run build, pruebas de rutas, pruebas de pago sandbox, pruebas de roles y revision visual pasen sin errores.

22 - ANEXOS TECNICOS Y REFERENCIAS

Comandos de instalacion

```

npm install next react react-dom
npm install tailwindcss @tailwindcss/forms framer-motion lucide-react
npm install @radix-ui/react-dialog @radix-ui/react-tabs @radix-ui/react-select
npm install zustand react-hot-toast react-dropzone axios date-fns zod
npm install next-auth @auth/prisma-adapter prisma @prisma/client
npm install stripe @paypal/checkout-server-sdk
npm install ioredis bullmq
npm install @aws-sdk/client-s3 @aws-sdk/s3-request-presigner
npm install resend @sentry/nextjs

```

Pruebas minimas Playwright

- usuario anonimo no entra a /dashboard

-
- login simulado crea usuario USER
 - USER no entra a /admin
 - ADMIN entra a /admin/users
 - USER sin plan no puede generar
 - USER con plan crea job
 - webhook Stripe activa subscription
 - webhook PayPal activa subscription
 - ruta admin sin role devuelve 403
 - rate limit devuelve 429 despues del umbral

Referencias oficiales usadas para esta expansion

Google OpenID Connect / OAuth 2.0 para login; Stripe Checkout, Subscriptions y webhooks para billing; PayPal REST Subscriptions y webhooks para pagos; Auth.js/NextAuth para autenticacion en Next.js. Validar endpoints exactos contra documentacion oficial al implementar porque los proveedores actualizan APIs y SDKs.

Nota de continuidad con v1

Esta version v2 se construye sobre el PDF maestro NEXFRAME_FILMS_CODEX_MASTER v1: mantiene la vision de estudio cinematografico IA, el stack Next.js + React + Tailwind, el motor Kling AI API, los studios, el dashboard, la arquitectura de archivos y el checklist original, ampliando la plataforma a SaaS multiusuario con pagos, seguridad y administracion completa.